SecureBank Financial | SecureMobile Platform: Executive Risk Dashboard

Prepared for the CISO and CFO

Total annual exposure	Residual exposure after controls	Annual risk reduction	Year-1 investment	Portfolio Year-1 ROI
$35,000,000	$8,037,500	$26,962,500 (77%)	$805,000	3,249%

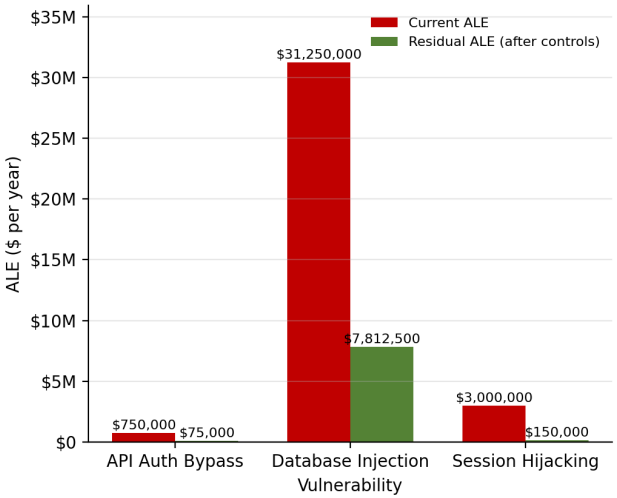
Top 3 risks by financial impact

#	Top risks	SLE	ARO	ALE	Priority
1	Database Injection	$125,000,000	25%	$31,250,000	Critical
2	Session Hijacking	$7,500,000	40%	$3,000,000	High
3	API Authentication Bypass	$5,000,000	15%	$750,000	Medium

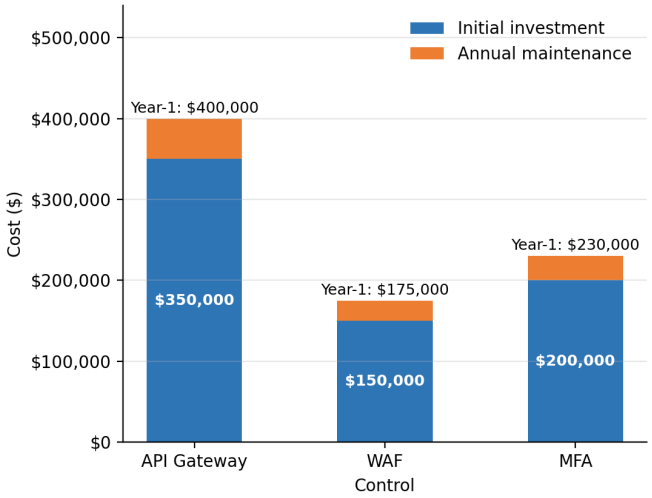
Recommended controls

Control	Year-1 cost	Risk reduction/yr	Year-1 ROI	Payback	Decision
API Gateway	$400,000	$675,000	69%	6.7 mo	Recommend
WAF	$175,000	$23,437,500	13,293%	0.1 mo	Recommend
MFA	$230,000	$2,850,000	1,139%	0.9 mo	Recommend
Total	**$805,000**	**$26,962,500**	**3,249%**	**0.3 mo**	

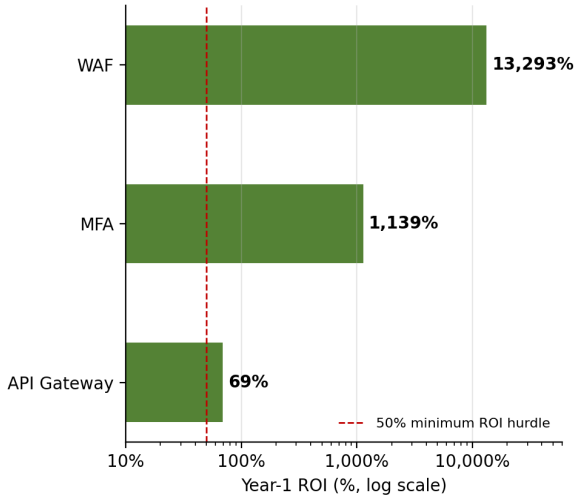
Risk Exposure Before vs After Controls



Control Investment Breakdown (Year 1)



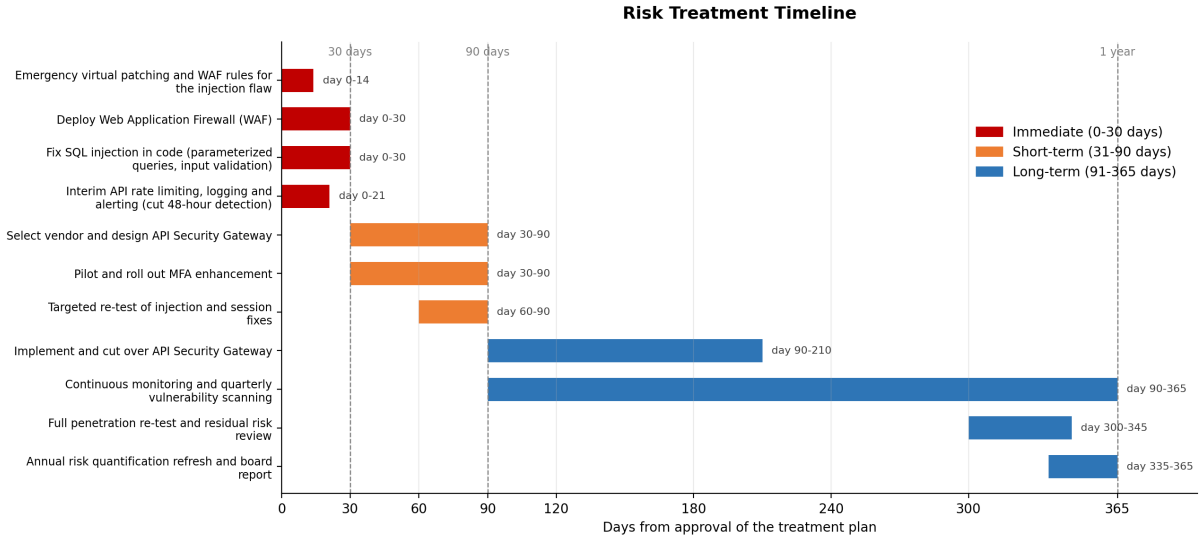
Year-1 ROI Across Controls



Key message: the database injection flaw drives 89% of total exposure. Deploy the WAF and fix the code first, then MFA, then the API gateway. Residual exposure of $8,037,500 is still material and needs root-cause fixes and monitoring.

Risk Treatment Plan

The plan sequences work by financial impact. The database injection flaw is 89% of total annual exposure, so the WAF, virtual patching and the code fix start on day one. MFA follows within 90 days, and the API gateway is delivered over the longer horizon because it has the lowest return of the three controls.



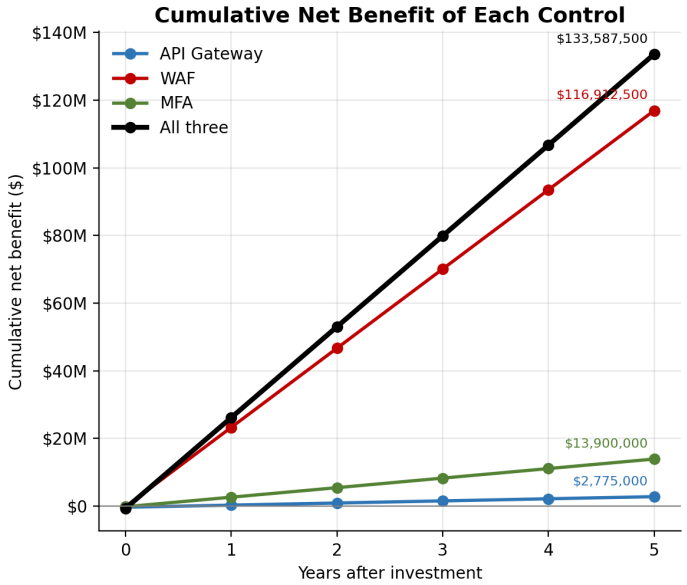
Phase	Action	Finding	Suggested owner
0-30 days	Apply virtual patching and deploy the WAF; fix SQL injection in code	Finding 2	AppSec lead / Infrastructure
0-30 days	Add API rate limiting, logging and alerting to cut the 48-hour detection time	Finding 1	Security operations
31-90 days	Roll out enhanced MFA; select vendor and design the API gateway; re-test fixes	Findings 1, 2, 3	IAM lead / Procurement
91-365 days	Implement the API gateway; continuous monitoring; full pen test; refresh the risk quantification	All findings	CISO / GRC

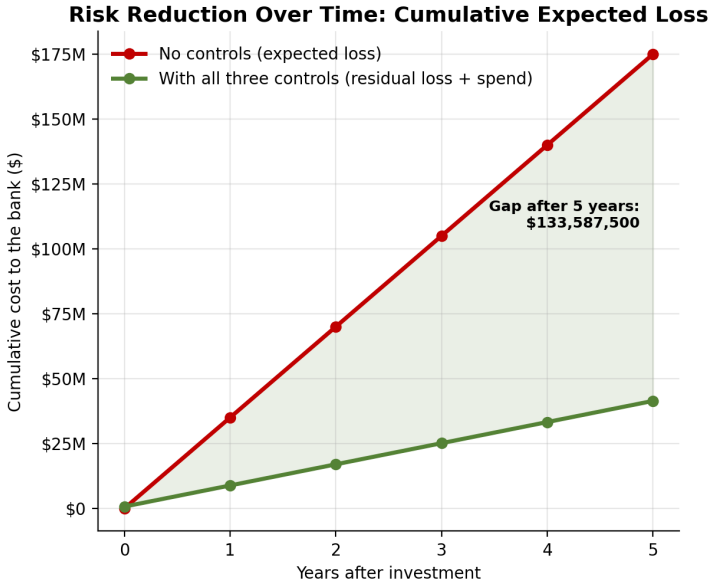
Owners are suggested roles, not named people. Dates run from the day the plan is approved.

Financial Justification

The three controls cost $805,000 in Year 1 ($700,000 initial plus $105,000 maintenance) and reduce expected annual loss by $26,962,500, from $35,000,000 to $8,037,500 (77%). Year-1 ROI is 3,249% and the 3-year ROI is 7,869%.

Control	Finding addressed	Y1 cost	Risk reduction / yr	Y1 ROI	Payback	3-yr ROI	Break-even effectiveness
API Gateway	API Authentication Bypass	$400,000	$675,000	69%	6.7 mo	305%	53.3%
WAF	Database Injection	$175,000	$23,437,500	13,293%	0.1 mo	31,150%	0.6%
MFA	Session Hijacking	$230,000	$2,850,000	1,139%	0.9 mo	2,848%	7.7%
Total		**$805,000**	**$26,962,500**	**3,249%**	**0.3 mo**	**7,869%**	





Key assumptions and limits

Each control is applied only to the finding it addresses and the effectiveness percentages are taken as given. The WAF's ROI is very high because it is credited with 75% of a $31,250,000 exposure, so the injection flaw must still be fixed in code. The API gateway is the marginal investment: it needs 53% effectiveness just to break even in Year 1, against a stated 90%. Finding 1 may be understated because a 48-hour detection window could allow losses above the stated $5,000,000 cap.